

ROLE PERMISSIONS

Module	Guest	Patient	Doctor (Pending)	Doctor (Approved)	Admin
Register (patient/doctor)	Yes	—	—	—	—
Login / Logout	Yes	Own session	Own session	Own session	Own session
View/edit own patient profile & pets	No	Own only	No	No	No
View/edit own doctor profile	No	No	Own only	Own only	No
Upload doctor documents	No	No	Own only	Own only	No
View doctor documents	No	No	No	No	Yes
Approve/reject doctors	No	No	No	No	Yes
Set own online/offline status	No	No	No (blocked)	Yes	No
Browse doctor directory	Limited	Yes	—	—	Yes
Send chat request	No	Yes, to approved online doctors	—	—	No
Accept/reject chat request	No	No	No	Own requests only	No
Send/read chat messages	No	Own sessions only	No	Own sessions only	No
View wallet balance/ledger	No	Own only	No	No	Yes, all (oversight)
Recharge wallet	No	Own only	No	No	Yes (test/manual)
View own earnings	No	No	No	Own only	Yes, all (reports)
Configure platform rate/commission	No	No	No	No	Yes
Submit support enquiry	Yes	Yes	Yes	Yes	—

Module	Guest	Patient	Doctor (Pending)	Doctor (Approved)	Admin
View/manage support enquiries	No	No	No	No	Yes

Legend: "Own only" / "Own session(s)" / "Own requests only" = ownership check required in addition to the role check. "—" = action not applicable to that role.

Two checks apply everywhere a role is restricted:

1. **Role check** — does the session's role match what's required?
2. **Ownership check** — does the resource belong to this specific logged-in user?

One exception: the Doctor role has an internal split — a "Doctor (Pending)" and "Doctor (Approved)" aren't different roles, they're the same role gated by an additional `approval_status` flag. Both checks (role and status) need to run independently, since checking only role would let a pending doctor slip into approved-only endpoints.